Automated VAPT Assessment & Triage Report

1. Engagement Scope & Rules of Engagement

Authorized Target Scope: 127.0.0.1:3000

Execution Timestamp: 2026-11-08 21:40:54

Rules of Engagement: Non-destructive local sandbox testing restricted strictly to authorized loopback assets.

2. Tools & Ingestion Sources

- Nmap Network Mapper: Live Subprocess Discovery
- OWASP ZAP (Web Application Scan): Import (Sample Data)
- Nikto (Server Configuration): Import (Sample Data)
- Nessus, OpenVAS/Greenbone, Burp Suite: Planned (not integrated) | Metasploit: Unsupported (lab-only, human-run)
- Correlation & Prioritization Engine: Groq (openai/gpt-oss-120b)

3. Risk Posture & Severity Distribution

Overall Posture Rating: MEDIUM

Severity Counts: Critical: 0 | High: 1 | Medium: 0 | Low: 4

4. Executive Summary

An open TCP port 3000 was detected on the target host, and multiple low?severity configuration issues were identified. A high?severity SQL injection vulnerability was also reported on the same service.

5. Attack Path Synthesis

1. Nmap confirmed that port 3000/tcp is open, indicating a reachable service (potentially PPP). 2. OWASP ZAP detected a SQL injection payload (' OR 1=1--) on the application listening on port 3000, allowing an attacker to manipulate database queries. 3. The same application lacks a Content Security Policy header, increasing the risk of client?side attacks such as XSS. 4. The server discloses its Express framework via the X?Powered?By header, providing useful information for an attacker. 5. Absence of the X?Frame?Options header leaves the site vulnerable to clickjacking attacks. These findings together create a plausible attack chain: an attacker discovers the open port, exploits the SQL injection to gain data access, and leverages missing security headers to execute further client?side attacks or reconnaissance.

Note: Sections 4 and 5 are AI-generated from the findings before analyst review. Findings later marked 'Rejected by Analyst' in section 7 are excluded from the roadmap but may still be mentioned in this narrative.

Data provenance: Nmap results come from a live scan of the lab target. ZAP and Nikto results are imported from files; findings titled 'Sample Data' come from recorded demonstration files, not from a live scan.

6. Remediation Roadmap

Priority 1 | ID: ZAP-40018 | Owner: Backend

Action: Implement input validation and use parameterized queries or prepared statements to eliminate SQL injection vectors.

Priority 3 | ID: NIKTO-999100 | Owner: Backend

Action: Remove or mask the X-Powered-By header to prevent framework disclosure.

Priority 5 | ID: NMAP-3000 | Owner: SecOps

Action: Verify the service running on port 3000 and restrict access via firewall or network segmentation as appropriate.

7. Finding Evidence & Provenance (5)

[LOW] Open Network Port: 3000 (service unidentified; Nmap port-table guess: ppp) (Tool: Nmap)

Target: 127.0.0.1:3000 | Confidence: 90% | Status: Reachable (HTTP 200); vulnerability not confirmed
Raw Source: outputs\nmap_target.xml
Trust Justification: Direct network enumeration: TCP connection and service response received.
Evidence: Port 3000/tcp open. Service (Nmap): service unidentified; Nmap port-table guess: ppp

[HIGH] Sample Data: SQL Injection (Tool: OWASP ZAP)

Target: 127.0.0.1:3000 | Confidence: 95% | Status: Reachable (HTTP 200); vulnerability not confirmed
Raw Source: imports\sample_zap_report.json
Trust Justification: Verified: Nmap independently confirmed port 3000 is open and reachable.
Evidence: ' OR 1=1--

[LOW] Sample Data: Content Security Policy (CSP) Header Not Set (Tool: OWASP ZAP)

Target: 127.0.0.1:3000 | Confidence: 100% | Status: Rejected by Analyst

Raw Source: imports\sample_zap_report.json
Trust Justification: Verified: Nmap independently confirmed port 3000 is open and reachable.
Evidence: Content Security Policy is missing from response headers.

[LOW] Sample Data: Server leaks information via X-Powered-By header: Express (Tool: Nikto (Import))

Target: 127.0.0.1:3000 | Confidence: 85% | Status: Reachable (HTTP 200); vulnerability not confirmed
Raw Source: imports\sample_nikto_report.json
Trust Justification: Verified: Nmap independently confirmed port 3000 is open and reachable.
Evidence: Sample Data: Server leaks information via X-Powered-By header: Express

[LOW] Sample Data: Anti-clickjacking X-Frame-Options header is not present. (Tool: Nikto (Import))

Target: 127.0.0.1:3000 | Confidence: 85% | Status: Rejected by Analyst
Raw Source: imports\sample_nikto_report.json
Trust Justification: Verified: Nmap independently confirmed port 3000 is open and reachable.
Evidence: Sample Data: Anti-clickjacking X-Frame-Options header is not present.

8. Limitations & Audit Trail

Limitations: Testing was strictly non-destructive and scoped solely to approved target ports. Safe HTTP probes evaluate endpoint reachability without verifying payload execution.

[2026-11-08 21:39:18] [BLOCKED] Scope violation blocked for target: 8.8.8.8
[2026-11-08 21:39:34] [AUTHORIZED] Plan approved by analyst for 127.0.0.1:3000
[2026-11-08 21:39:47] [OK] Nmap scan completed: 1 port(s) detected
[2026-11-08 21:40:00] [AUTHORIZED] Plan approved by analyst for 127.0.0.1:3000
[2026-11-08 21:40:12] [OK] Nmap scan completed: 1 port(s) detected
[2026-11-08 21:40:22] [OK] Correlation completed via Groq (openai/gpt-oss-120b)
[2026-11-08 21:40:40] [VERIFIED] Benign probe on NMAP-3000 -> Reachable (HTTP 200); vulnerability not confirmed
[2026-11-08 21:40:45] [VERIFIED] Benign probe on ZAP-40018 -> Reachable (HTTP 200); vulnerability not confirmed
[2026-11-08 21:40:49] [REJECTED] Finding ZAP-10038 rejected by analyst
[2026-11-08 21:40:51] [VERIFIED] Benign probe on NIKTO-999100 -> Reachable (HTTP 200); vulnerability not confirmed
[2026-11-08 21:40:54] [REJECTED] Finding NIKTO-999101 rejected by analyst